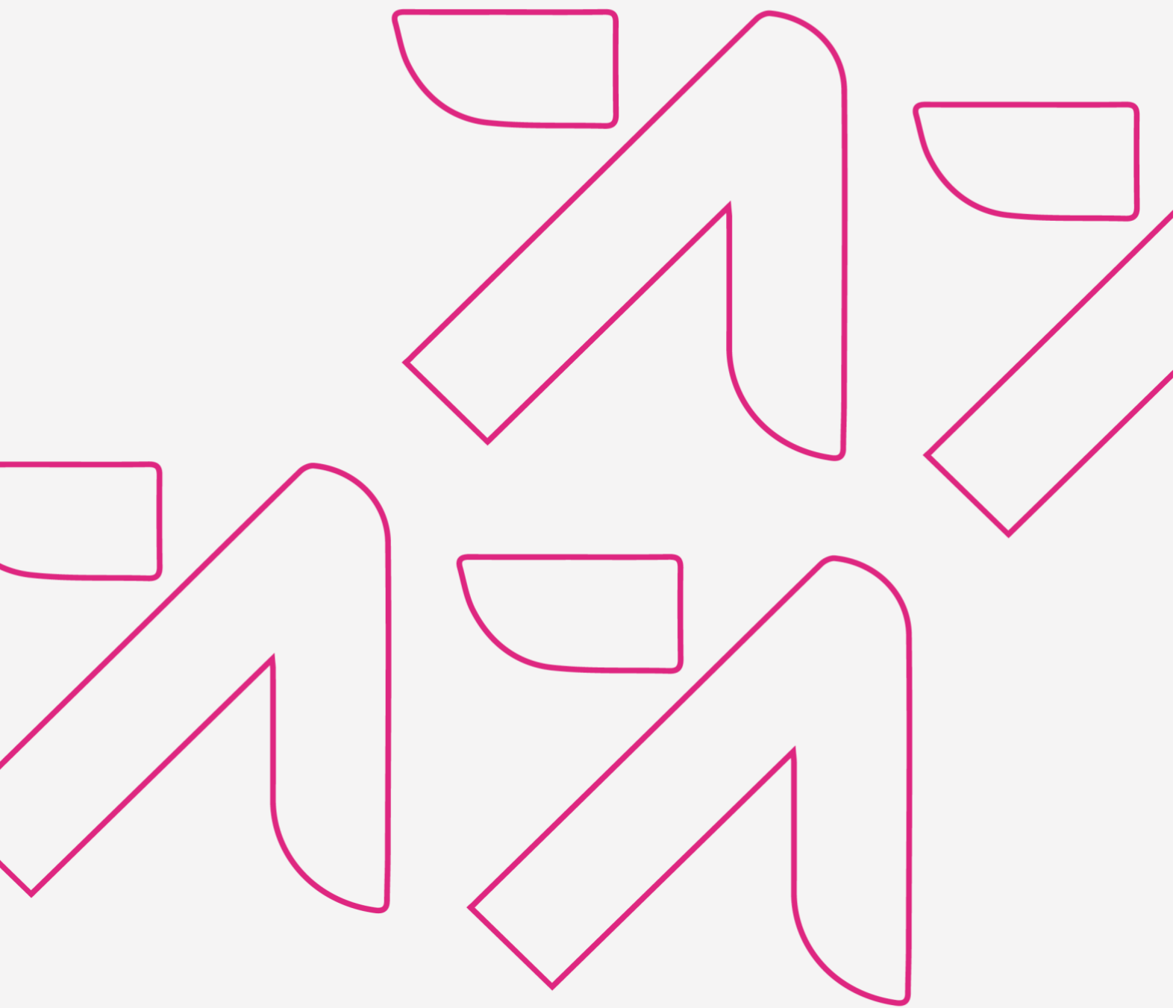




Máster de

# Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

## UT5 – Actividad 1. Diseño de roles (RBAC)

**Encaje en el curso 2026/2027:** RA2 · tema 3 y RA3 · temas 4 y 5 del temario oficial.

### 1. Enunciado

Diseña una **estructura de roles y permisos** siguiendo un modelo RBAC para una organización. El objetivo es que definas qué roles existen, qué permisos tiene cada uno y por qué esa distribución respeta el principio de mínimo privilegio.

### 2. Guía paso a paso

1. Piensa en las funciones habituales de una organización (administración, usuarios estándar, soporte, dirección...).
2. Define entre 3 y 6 roles que tengan sentido real.
3. Asigna a cada rol solo los permisos necesarios para desempeñar su función.
4. Evita roles “todopoderosos” salvo que sea estrictamente necesario.
5. Explica en una frase por qué cada rol necesita esos permisos y no más.
6. Presenta todo en una tabla clara: Rol / Permisos / Justificación.

**Reto extra (opcional):** identifica dos combinaciones de permisos que nunca deberían recaer en la misma persona (segregación de funciones) y explica cómo lo impedirías.

## UT5 – Actividad 2. Revisión de cuentas de servicio

### 1. Enunciado

Analiza varios ejemplos de **cuentas de servicio** y determina si están correctamente configuradas o presentan riesgos. El objetivo es aprender a identificar permisos excesivos, credenciales mal gestionadas o configuraciones inseguras.

### 2. Guía paso a paso

1. Redacta una lista breve de **cuentas de servicio** típicas (bases de datos, automatizaciones, backups...).
2. Para cada una, revisa mentalmente:
  - Qué función cumple
  - Qué permisos debería tener
  - Qué permisos NO debería tener
  - Cómo se debería gestionar su contraseña o clave

3. Detecta configuraciones incorrectas (por ejemplo: uso de cuentas personales, privilegios de administrador, contraseñas sin rotación).
4. Propón cómo debería configurarse correctamente cada caso.
5. Resume los riesgos encontrados y las mejoras sugeridas.

**Reto extra (opcional):** elige una de las cuentas y describe cómo sacarías su credencial del script o del fichero donde está para llevarla a un gestor de secretos, y cómo se rotaría.

## UT5 – Actividad 3. Flujo de autenticación seguro

### 1. Enunciado

Documenta un **flujo de autenticación seguro** para acceder a un servicio sensible de la organización, incluyendo: contraseña robusta, segundo factor (MFA) y asignación de privilegios mínimos.

### 2. Guía paso a paso

1. Piensa en un servicio sensible típico (correo corporativo, VPN, portal interno...).
2. Describe cómo debería autenticarse un usuario paso a paso.
3. Incluye requisitos mínimos de la contraseña y el tipo de MFA recomendado.
4. Indica cómo se valida que el usuario tenga los permisos adecuados.
5. Explica brevemente cómo se controla el acceso desde dispositivos o ubicaciones no confiables.
6. Redacta el flujo final en un formato claro, tipo lista ordenada.

**Reto extra (opcional):** rediseña el flujo usando passkeys (FIDO2) en lugar de contraseña más código y explica qué ataques dejan de funcionar.